Hermes Private Review Packet

ADR-009..ADR-014 | Phase-4 Preconditions

Hermes Private Review Packet - Combined_DRAFT - Private Review Only_

Executive Summary

Hermes Private Review Packet (Draft — Private Review Only)

Status: DRAFT (Private review — do NOT publish)

Executive Summary

This packet contains the Phase-3 → Phase-4 preconditions for Hermes review. It includes the six ADR addenda (ADR-009…ADR-014), the Phase-4 test plan, and the Hermes sign-off packet. This is for private review only; do not push a branch or open a PR until Hermes provides private approval to proceed to the formal PR step.

Contents

1. ADR Addenda (see `docs/adr/`):
   - ADR-009 — Key Management & Signing
   - ADR-010 — Time & Clock Skew
   - ADR-011 — Revocation Registry & SLA
   - ADR-012 — Monotonic Counters & HA
   - ADR-013 — Canonical Serialization
   - ADR-014 — Tamper-Evident Audit Chain
2. Phase-4 Test Plan (see `docs/hermes_review/phase4_test_plan.md`) — outlines unit, integration, and load tests that map directly to the ADR acceptance criteria.
3. Hermes Sign-off Packet (see `docs/hermes_review/hermes_signoff_packet.md`) — contains the acceptance checklist and the sign-off template.

Private Review Instructions

- Read the ADRs and Phase-4 test plan for coverage and acceptance criteria.

- Use the acceptance checklist in the Hermes sign-off packet to validate readiness.
- If no objections, provide **private approval** (see `private_approval_statement.txt`) which allows the team to open the formal PR. This private approval is *not* a public GitHub approval; it is a governance green light for creating the PR.

PDF generation (optional)

To produce a PDF for Hermes use (run locally):

```
# Install pandoc if needed, then:
pandoc -s hermes_private_review_packet.md -o Hermes_Private_Review_Packet.pdf
```

Security & Handling

- This packet is confidential until Hermes authorizes PR publication.
- Do not distribute or publish these materials outside the Hermes review process.

Contact

For questions, tag: @hermes (review), @security (policy), @infra (test infra).— ## ADR Addenda (009..014) ### ADR-009-key-management.md Status: Draft (For Hermes Review)

Decision

Hermes is the sole key authority; all Delegation Objects (DOs) and Revocation Objects (ROs) MUST be signed by Hermes-managed keys.

Context

Phase 3 design requires unforgeable delegation, verifiable revocation, and deterministic enforcement. Key ownership and rotation must not dilute authority.

Consequences • No delegate may generate or rotate authority keys. • Signature verification is mandatory on every guarded execution. • Key rotation is Hermes-only and backward-verifiable for active DOs.

Acceptance Criteria • All DOs/ROs include a Hermes signature. • Verification failure deny (fail-closed). • Key rotation does not invalidate unexpired DOs. • Public verification material is read-only to delegates.

Code / Tests • ct_runtime/core/keys.py (new) • guarded_executor.py (verify signatures) • Tests: signature verify, invalid key, rotation continuity ### ADR-010-time-clock-skew.md Status: Draft (For Hermes Review)

Decision

Hermes defines canonical time; all policy evaluation uses a single abstracted clock with bounded skew tolerance.

Context

TTL enforcement, cooldowns, and revocation require deterministic time semantics across nodes.

Consequences • All time access routes through core/time.py. • Delegates may not override time sources. • Excessive skew results in deny, not correction.

Acceptance Criteria • No direct datetime.utcnow() usage in enforcement paths. • Skew tolerance is explicit and bounded. • Time uncertainty deny execution.

Code / Tests • ct_runtime/core/time.py (new) • Replace inline datetime usage • Tests: skew tolerance, expired DO, future-issued DO ### ADR-011-revocation-sla.md Status: Draft (For Hermes Review)

Decision

Revocation is immediate, authoritative, and SLA-bound; failure to confirm revocation state MUST deny execution.

Context

Phase 3 requires revocation to override all other permissions deterministically.

Consequences • Hermes maintains the revocation registry. • Delegates must check revocation state before every invocation. • Registry unavailability fail-closed.

Acceptance Criteria • Revoked DOs cannot execute within SLA bounds. • Revocation checks occur per invocation. • Revocation events are auditable and signed.

Code / Tests • ct_runtime/core/revocation.py (new) • guarded_executor.py (revocation check) • Tests: revoked DO, registry unreachable, SLA timing ### ADR-012-monotonic-counters.md Status: Draft (For Hermes Review)

Decision

Hermes enforces monotonic counters per delegation to prevent replay and reordering.

Context

Nonce-only systems are insufficient under retry and network reordering scenarios.

Consequences • Hermes tracks counters per delegation_id. • Out-of-order or reused counters deny + incident. • Counters survive restarts (durable).

Acceptance Criteria • Counter regression always denied. • Counters are monotonic and persisted. • Replay attempts emit security audit events.

Code / Tests • ct_runtime/core/counters.py (new) • guarded_executor.py (counter enforcement) • Tests: replay, out-of-order, restart continuity ### ADR-013-canonical-serialization.md Status: Draft (For Hermes Review)

Decision

All signed artifacts (DOs, ROs, audit hashes) use a canonical, deterministic serialization.

Context

Non-canonical JSON breaks signature verification and audit integrity.

Consequences • Canonical serialization is mandatory before signing or hashing. • Field order, encoding, and whitespace are fixed. • Any non-canonical input deny.

Acceptance Criteria • Identical logical payloads produce identical bytes. • Signature verification fails on non-canonical input. • Golden vectors validate serialization stability.

Code / Tests • ct_runtime/core/serialization.py (new) • Tests: golden vectors, reordering, whitespace variance ### ADR-014-tamper-evident-audit.md Status: Draft (For Hermes Review)

Decision

The audit log is append-only and cryptographically chained; tampering must be detectable.

Context

Hermes audit records are the system of record for governance and incident response.

Consequences • Each audit entry hashes the previous entry. • Any break in the chain is a security incident. • Verification tooling is mandatory.

Acceptance Criteria • Audit chain verification detects modification, deletion, or reordering. • Hermes is the only writer of authoritative audit entries. • Verification can be run offline.

Code / Tests • Extend audit.py (hash chaining) • tools/audit_verify.py (new) • Tests: tamper detection, truncation, reorder —## Phase-4 Test Plan Phase-4 Test Plan

Status: Draft (Phase-4 gating; Hermes review required)

Executive Summary

This test plan directly validates the acceptance criteria in ADR-009…ADR-014. It defines unit, integration, and load tests that must pass (or be explicitly acknowledged with mitigations) before Phase-4 enforcement wiring is merged.

Gating Principle

Every acceptance criterion in the ADR addenda maps to at least one automated test. Phase-4 is blocked until all critical tests pass and Hermes explicitly signs off.

Test Matrix

1) Signing & Canonical Serialization

- Type: Unit / Integration
- Description: Verify that all signed artifacts (DOs, ROs, audit checkpoints) are serialized using the canonical serializer and validate signatures using Hermes public keys. Cover key rotation scenarios and invalid key cases.
- Expected Outcome: Canonical bytes match golden vectors; signature validation succeeds for valid keys and fails otherwise.
- Automation Hook: `tests/integration/test_signing.py`, `scripts/phase4_signing_test.py`
- Test Data: Keypair fixtures, canonical serialization vectors, rotated-key scenarios

2) Revocation Enforcement & Propagation SLA

- Type: Integration / Load
- Description: Issue a revocation and verify immediate local enforcement; measure propagation latency to remote nodes/observers and assert it meets SLA (e.g., internal <30s, cross-federation <5m).
- Expected Outcome: Revoked DOs denied immediately; propagation latency within SLA for 99th percentile.
- Automation Hook: `tests/integration/test_revocation_propagation.py`, `scripts/phase4_revocation_sla.py`
- Test Data: Two-node topology (authority + observer), revocation events, timing harness

3) Monotonic Counters & Anti-Replay

- Type: Load / Integration
- Description: Simulate high-concurrency increments, node failover and restart, and validate counter monotonicity and no duplicates/replays.
- Expected Outcome: No counter duplication or regression after failover; replay attempts rejected and audited.
- Automation Hook: `tests/load/test_counters.py`, `scripts/phase4_counter_failover.py`
- Test Data: High-concurrency workloads, failover scripts

4) Tamper Detection on Audit Log

- Type: Integration
- Description: Create audit records, then tamper records (modify/delete/reorder) and run verification tool to detect anomalies.
- Expected Outcome: Verification detects tampering and reports exact discrepancies; integrity verification script passes against untampered logs.
- Automation Hook: `tools/audit_verify.py`, `tests/integration/test_audit_tamper_detection.py`
- Test Data: Sample audit DB snapshot, tampered snapshot

5) Clock Skew & Expiry Enforcement

- Type: Integration
- Description: Inject clock skew into TimeProvider, test issuance and expiry of DOs/ROs, and verify that extreme skews cause deny and alerting.

- Expected Outcome: Expiry and issuance windows respected; extreme skews cause fail-closed behavior and alerts.
- Automation Hook: `tests/integration/test_clock_skew.py`, `scripts/phase4_clock_skew.py`
- Test Data: Delegation tokens with lifetimes, controlled clock injection

6) Metrics & SLA Regression

- Type: Integration / Smoke
- Description: Validate metric emission for revocations, propagation latency, key rotations, audit verification, and counters. Gate PRs on no metric regressions.
- Expected Outcome: Metrics available and within thresholds; regression test fails if metrics deviate from baseline.
- Automation Hook: `tests/integration/test_metrics_sla.py`, metrics smoke tests
- Test Data: Metrics endpoints, expected threshold values

Automation & CI

- Add these tests to CI (prefer staged runs): unit fast tests per-commit; integration tests on PR; load tests on scheduled pipelines or dedicated infra.
- Provide `scripts/` harnesses for timing-sensitive tests (revocation propagation, counter failover, clock skew) that can run in CI or local lab environments.

Acceptance Criteria for Merge

- All unit tests pass.
- All integration tests pass in an infra-approved environment (or exceptions documented and accepted by Hermes).
- Load tests indicate counters and revocation checks meet performance SLOs at expected load.
- Audit verification tooling reports no integrity issues.

Runbook Notes (short)

- Test infra must allow time control (fake-time injection or container time namespaces) for deterministic skew testing.
- Revocation propagation tests need at least two nodes (authority + observer) and controllable network latency.

Contact

Tag: @hermes (approval), @qa (test infra)—## Hermes Sign-off Packet Hermes Sign-off Packet (Phase-4 Preconditions)

Status: Draft (Hermes review required)

Summary

This packet summarizes the ADR addenda (ADR-009…ADR-014), the Phase-4 test plan, and the exact acceptance criteria required for Hermes sign-off prior to enforcement wiring.

Core Decisions (short) - Hermes is sole authority for keys and signatures (ADR-009).
- Time is canonical and bounded by explicit skew (ADR-010).
- Revocation is authoritative and SLA-bound (ADR-011).
- Counters are per-delegation and monotonic with HA durability (ADR-012).
- A canonical serializer is required for signing/hashing (ADR-013).
- Audits are append-only and chained for tamper detection (ADR-014).

Hermes Acceptance Checklist (PR sign-off) - [ ] ADR-009 … ADR-014 are accepted by Hermes.
- [ ] Phase-4 Test Plan (`docs/hermes_review/phase4_test_plan.md`) is accepted (or test infra exceptions documented).
- [ ] Implementation plan(s) submitted and reviewed for each module (`core/keys.py`, `core/time.py`, `core/revocation.py`, `core/counters.py`, `core/serialization.py`, audit chaining).
- [ ] DB schema/migration plan for revocation, counters, and audit chain included and reviewed.
- [ ] CI plan for gated tests (unit, integration, load) and required infra is accepted.

Hermes Sign-off Template (copy-paste)

> Reviewed ADR-009..ADR-014; acceptance criteria satisfied. Hermes signs off — proceed to Phase-4 enforcement wiring.

Post-Signoff Requirements

- Merge small, focused implementation PRs with accompanying tests (per the Implementation PR Checklist).
- Add runtime observability dashboards for revocation, counters, and audit integrity.
- Schedule an enforcement rollout window with security monitoring enabled.

Contact

Tag: @hermes (approval), @security (incident handling), @infra (test infra)— ## Implementation PR Checklist Phase-4 Implementation PR Checklist

Status: Draft (Implementation guidance & PR gating)

Purpose

Break Phase-4 into small, reviewable PRs with clear acceptance tests and minimal blast radius. Use this checklist as a template for each implementation PR.

Per-PR Template (required items) - PR scope description (one sentence).
- ADR reference(s) (which ADRs this PR implements).
- Code changes limited to a single concern (e.g., `core/time.py` + tests only).
- Unit tests added and passing.
- Integration tests added or a ticket pointing to test infra (if test requires multi-node infra).
- DB migration included (if persistent state added) and migration test included.
- Observability: Metrics added and documented.
- Security: Signature/key usage reviewed and threat model OK.
- Ops: Runbook or rollback notes included (key rotation, audit verify steps).

Suggested PR grouping & priorities 1) `core/time.py` + replace inline datetime usage (low risk).
2) `core/serialization.py` + golden vector unit tests (blocks signing and audits).
3) Audit chain changes in `core/audit.py` and `tools/audit_verify.py` + integration tamper tests.
4) `core/keys.py` (KMS/HSM abstraction + software fallback) + signing/verification tests.
5) `core/revocation.py` (registry + propagation hooks) + per-invocation tests + metrics.
6) `core/counters.py` (HA monotonic counters) + failover tests and load testing.

CI Requirements - Unit tests run on every PR.
- Integration tests (time-sensitive, multi-node) run on merge candidate or scheduled pipeline with dedicated infra.
- Load tests for counters and revocation propagation run in staging prior to wide rollout.

Merge Criteria - All required tests pass and performance SLOs met or an explicit mitigation is approved.
- DB migrations reviewed and rollback tested.
- Observability dashboards present basic SLOs and alerts.

Rollout Guidance - Feature-flag enforcement wiring to allow staged rollout (disable by default).
- Canary enforcement on a small subset of traffic, monitor audit + metrics for 24–72 hours.
- Full rollout only after successful canary and no critical incidents.

Contact

Tag: @hermes (design), @security (policy), @infra (test infra)—## Walkthrough Agenda Hermes Private Review — Walkthrough Agenda (15–30

minutes)

Status: DRAFT (Private review only)

Proposed Agenda (15–30 min)

1. Opening (1 min)
   - Purpose and expected outcome (private approval to open PR)
2. Context & invariants (3–5 min)
   - Hermes as single authority (ADR-001 summary)
   - Scope grammar & deny-by-default (link to ADRs)
3. What ADR-009..ADR-014 lock (8–10 min)
   - For each ADR: Decision (one line), key acceptance criteria, and system impact
     - Key Management & Signing (ADR-009)
     - Time & Clock Skew (ADR-010)
     - Revocation SLA & Registry (ADR-011)
     - Monotonic Counters & HA (ADR-012)
     - Canonical Serialization (ADR-013)
     - Tamper-Evident Audit Chain (ADR-014)
4. Phase-4 Test Plan & gating (3–5 min)
   - Highlight critical tests and SLOs (revocation propagation latencies, counter load) and handoff to infra for integration runs
5. Questions & Confirms (3–5 min)
   - Any requested wording changes or conditions for approval
   - If accepted: confirm private approval statement and next steps to open PR
6. Next steps & close (1 min)
   - Expected timeline for PR creation and public review

Notes

- Keep discussion focused on acceptance criteria and measurable tests.

- If Hermes requests edits, we will apply only requested modifications and return for re-check.—## Private Approval Statement Private Approval Statement (for Hermes private review)

Template:

Reviewed ADR-009..ADR-014 for private review. No objections to proceeding to a formal PR for Phase-4 preconditions.

Notes: - This statement is signature-of-intent only and is *not* a GitHub PR approval.
- Once this private approval is received, the team will open the formal PR and assign Hermes as reviewer for public approval.